CARLOS GABRIEL GOMES LUZ

APPLICATION SECURITY (APPSEC) | DEVSECOPS | ENGENHARIA DE SOFTWARE

São Paulo, SP | +55 (11) 96762-2665 | carlosgabriel.contato2007@gmail.com
linkedin.com/in/dev-carlosgabriel | github.com/CarlossgLuz | carlosg.com.br

RESUMO PROFISSIONAL

Analista de Desenvolvimento de Sistemas Jr. com experiência prática em AppSec, ASPM e DevSecOps e foco de carreira em segurança de aplicações. Atuação na evolução do XGuardian, envolvendo análise de vulnerabilidades, segurança da cadeia de software, RBAC, métricas e automação. Desenvolvo projetos próprios de segurança de APIs e governança de agentes de IA, unindo Python, testes, políticas de execução e rastreabilidade.

EXPERIÊNCIA PROFISSIONAL

Xmart Solutions | Santo André, SP

Analista de Desenvolvimento de Sistemas Jr. | jun/2026 – atual

- Evolução do XGuardian, plataforma SaaS de AppSec e ASPM, com melhorias em funcionalidades e relatórios de SAST, SCA, DAST, Container Security e SBOM, favorecendo a visualização e a contextualização de achados de segurança.
- Desenvolvimento e aprimoramento de dashboards, métricas, filtros e fluxos de análise de vulnerabilidades, incluindo controles de cotas de scans por aplicação e equipe, com foco na consistência das informações e na usabilidade operacional.
- Atuação na investigação e contextualização de vulnerabilidades e dependências com referências como OWASP Top 10, NIST NVD, MITRE CVE/CWE, CVSS e GitHub Advisory Database, considerando também o fim de suporte (EOL) de componentes.
- Participação, junto à equipe, no levantamento e desenvolvimento de controles RBAC, envolvendo perfis, permissões, segregação de acesso e proteção de operações e APIs para a plataforma.
- Apoio técnico e suporte ao ecossistema Sonatype, documentação e troubleshooting de ambientes corporativos, incluindo um cenário do setor financeiro para utilização de centenas de desenvolvedores. Além da participação em reuniões técnicas com os fornecedores, conduzidas em inglês. Hoje sendo a Xmart Solutions a empresa brasileira parceira da Sonatype com diversos profissionais especializados e capacitados para implementação e suporte do ecossistema Sonatype.
- Participação na parceria técnica entre Xygeni e Xmart Solutions, com acesso à plataforma, capacitação conduzida por especialistas e avaliação de recursos de AppSec e segurança da cadeia de software.
- Utilização do Semgrep, OWASP ZAP, Gitleaks e Dependabot em estudos e validações.
- Fluxo de trabalho aplicado a IA generativa e automações relacionadas a atividades de engenharia e segurança, integrando modelos, agentes e ferramentas por APIs e MCP para apoiar análises técnicas, documentação, QA e execuções controladas de fluxos, com atenção a permissão e proteção de dados, gerenciando toda governança de agentes e auditando decisões.

Estagiário de Desenvolvimento de Sistemas | dez/2025 – jun/2026

- Atuação em suporte técnico, ambientes Linux e Proxmox, observabilidade com Zabbix e Grafana e desenvolvimento web, além de responsabilidades relacionadas a Redes e Infraestrutura. Ampliação progressiva de responsabilidades até a efetivação.

FORMAÇÃO ACADÊMICA

UNICID | Tecnologia em Análise e Desenvolvimento de Sistemas | jun/2026 – em andamento

SENAI | Técnico em Desenvolvimento de Sistemas | jul/2024 – jun/2026

PROZ | Técnico em Informática para Internet | jan/2023 – dez/2024

PROJETOS E INICIATIVAS SELECIONADAS

APIsec | laboratório autoral de segurança de APIs

Laboratório público em FastAPI que simula falhas BOLA, BFLA e BOPLA (OWASP API Security Top 10:2023), comparando cenários vulneráveis e protegidos. Testes com Pytest, análise estática com Ruff e Bandit, GitHub Actions, Docker e geração de relatórios Markdown/JSON. Cenários isolados, dados fictícios e sem exploração de terceiros. github.com/CarlossgLuz/APIsec-LabTest

Open-Vaultin | AI Agent Harness Governance | open source

Projeto autoral open source em evolução contínua (Early V1), escrito em Python. Camada local-first de governança de agent harness: agentes e skills, políticas, roteamento de tarefas com modelo decisor JEV/TypeSafe e fallback determinístico, hooks do Codex, registro persistente de execuções, evidências, conhecimento versionado e sincronização Git/MCP. O cliente permanece responsável pelo loop principal; enforcement depende da integração. github.com/CarlossgLuz/Open-Vaultin

Sistema de QA automatizado | iniciativa interna

Desenvolvimento de solução de validação pré e pós-release para funcionalidades, integrações, permissões e pipelines por APIs, com execuções controladas, coleta de evidências e rastreabilidade.

Benchmarking de ferramentas SAST

Elaboração de cenários controlados com referências como OWASP Benchmark para avaliar cobertura, precisão, falsos positivos e falsos negativos, apoiando comparações técnicas.

COMPETÊNCIAS TÉCNICAS

AppSec / DevSecOps: ASPM, SAST, SCA, DAST, Container Security, Secrets Scanning, SBOM, Secure SDLC, vulnerabilidades, supply chain security, RBAC.

Análise de segurança: OWASP Top 10, OWASP API Security Top 10, NVD, CVE/CWE, CVSS, GitHub Advisory Database; testes de autorização BOLA/BFLA/BOPLA.

Ferramentas: Sonatype Nexus Repository/Lifecycle/Firewall, XGuardian, Xygeni, Semgrep, OWASP ZAP, Gitleaks, Dependabot, Ruff, Bandit, Pytest.

IA / automação: AI Agent Harness Governance, agentes/skills, JEV/TypeSafe, roteamento e fallback, MCP, APIs, registros de execução, CI/CD.

Desenvolvimento / operações: Python, FastAPI, JS/TS, React/Next.js, SQL, Git, GitHub Actions, GitLab CI/CD, Linux, Docker, AWS/Azure, Proxmox, Zabbix/Grafana.

CERTIFICAÇÕES E IDIOMAS

Microsoft Azure Fundamentals (AZ-900) | fev/2026 • Scrum Foundation Professional Certification (SFPC) | out/2024

Inglês: B2 (intermediário superior) | documentação e reuniões técnicas; em aperfeiçoamento.